

Information Security Policy

HD Laser Studio INC · 759 Turquoise St, San Diego, CA 92109 · Version 1.0 · Effective September 23, 2026 · Review annually and after any material change

1. Purpose and scope

This policy sets out how HD Laser Studio protects the information it holds: customer contact details and orders, employee records, and the company's own financial data, including bank and card transactions retrieved through Plaid. It applies to the owner, every employee and contractor, and every system the company uses.

2. Responsibility

The owner, Hugh Demiral (contact@hdlaser.net), is responsible for information security: approving access, responding to incidents, and reviewing this policy. There is no separate IT department; the systems are hosted services managed by the owner.

3. Systems and where data lives

SYSTEM	WHAT IT HOLDS	WHO HAS ACCESS
Cloudflare (Workers, D1 database, secrets)	Order records, customer contacts, employee records and shift history, financial ledger, bank access tokens	Owner only, via the Cloudflare account
Owner dashboard (hdlaser.net → Owner login)	Sales, financial and team reports	Owner and managers, by admin password
Staff portal (hdlaser.net/staff)	Each employee's own shifts, checklists, jobs and pay estimate	Each employee, by personal PIN; managers see team data; no financial data
Square	Payments, refunds, payouts	Owner; employees by individual passcode with limited permissions
Plaid	Read-only connection to company bank and card accounts	Owner only
Twilio, Resend, Google Workspace	Texts, transactional email, company email	Owner
GitHub (website source)	Website code; no customer or financial data	Owner and the site maintainer

4. Access control and authentication

1. Every person has their own login. Shared or "master" accounts are not used. Employees sign in to the portal with an individual PIN and to Square with an individual passcode.
2. Access follows the job: employees see only their own data and the work queue; managers see team data; only the owner sees financial data and bank connections.
3. Multi-factor authentication is enabled on the Cloudflare, Plaid, Square, Google Workspace and GitHub accounts.
4. When someone leaves, the owner deactivates their portal login the same day, which ends their sessions immediately, and removes their Square passcode.
5. Access rights are reviewed at least every six months.

5. Secrets and credentials

1. API keys, tokens and passwords are stored only as encrypted secrets in Cloudflare. They are never written into code, documents, chat, or email.
2. Any credential that is exposed, or suspected exposed, is rotated at the provider and replaced in Cloudflare the same day.
3. Bank access tokens issued by Plaid are stored in the Cloudflare database, reachable only through the owner's account. Disconnecting a bank from the dashboard revokes the token at Plaid and deletes it locally.

6. Data handling

1. All data moves over encrypted connections (HTTPS/TLS). Stored data is encrypted at rest by Cloudflare.
2. Financial and bank data is used only to run the company's own accounting: categorizing transactions, reconciling with Square, and forecasting cash. It is not sold and not shared with third parties. Customer marketing consent is handled under the Terms of Sale and Privacy Notice at hdlaser.net/terms.
3. Bank data is retrieved read-only. The company's systems cannot move money.
4. Exports (CSV) are made only by the owner, stored on company devices, and deleted when no longer needed.
5. Customers may request a copy or deletion of their data by emailing contact@hdlaser.net; requests are handled within 30 days.

7. Devices

1. Company systems are accessed from devices with a screen lock and current operating system updates.
2. Financial systems are not accessed from shared or public computers.

3. Lost or stolen devices are reported to the owner immediately; sessions are ended and passwords changed.

8. Vendors

The company relies on established providers for hosting and financial data: Cloudflare, Square, Plaid, Twilio, Resend, Google and GitHub. Each is used under its standard terms, with access limited to what the company needs. New vendors that would hold customer or financial data are approved by the owner before use.

9. Incident response

1. Anyone who notices something wrong (unexpected access, a lost device, a suspicious email, a credential in the wrong place) tells the owner at once.
2. The owner contains the issue first: rotate credentials, deactivate logins, disconnect the affected service.
3. The owner records what happened, when, what data was involved, and what was done, and keeps the record for three years.
4. If personal data of customers or employees was exposed, affected people and any authorities required by California law are notified without undue delay.

10. Backups and availability

Website source is version-controlled on GitHub. The operational database is hosted by Cloudflare with provider-managed durability; the owner exports the financial ledger and order records to CSV at least monthly and keeps the exports on a company device.

11. Training and acknowledgment

Every employee reads this policy and the Standard Operating Procedure on their first day and confirms it to the owner. Key points are repeated in the SOP's checkout and refund rules: individual logins only, never share a PIN or passcode.

12. Review

The owner reviews this policy at least once a year and whenever a system, vendor, or the way data is used changes. Changes are dated and the version number is increased.

Adopted by: _____ Hugh Demiral, Owner Date: _____